

MOBILE APP SECURITY QUESTIONNAIRE

Project / App Name

Course / Class

Team Members

Date

Instructor

Purpose

This questionnaire helps the security analyst on the team understand what the app does, how it is built, and where potential risks might exist. Fill it out as early as possible so security considerations can be addressed during development. If something hasn't been decided yet, write TBD. If a question doesn't apply, write N/A with a brief reason.

1. App Overview

What is the app, who is it for, and what kind of data does it touch?

#	Question	Response
1	What is the app name and a one-sentence description of what it does?	
2	What platform(s) is it being built for (iOS, Android, cross-platform)?	
3	Who are the target users?	
4	Does the app require user accounts or login?	
5	What types of data will the app collect or store (e.g., names, emails, location, photos)?	

2. Technology Stack

What tools, frameworks, and services make up the app?

#	Question	Response
1	What language and framework are you using (e.g., Swift, Kotlin, React Native, Flutter)?	
2	What back-end or server technology are you using, if any (e.g., Firebase, Node.js, Django)?	
3	What database are you using (e.g., Firebase Realtime DB, SQLite, PostgreSQL)?	

MOBILE APP SECURITY QUESTIONNAIRE

4	List any third-party libraries, SDKs, or APIs your app depends on.	
5	Where is the back-end hosted (e.g., Firebase, AWS, Heroku, university server)?	

3. Authentication, Data Storage & Secrets

How are users identified, how is data protected, and where do secrets live?

#	Question	Response
1	How do users authenticate (e.g., email/password, Google Sign-In, Firebase Auth)?	
2	Are passwords hashed before storage? If so, what algorithm (e.g., bcrypt, Argon2)?	
3	Is there any role-based access (e.g., admin vs. regular user)?	
4	Is data transmitted over HTTPS? Are there any plain HTTP endpoints?	
5	Is any sensitive data stored locally on the device? If so, is it encrypted?	
6	How are API keys or secrets managed? Are any hardcoded in the app?	
7	If using a database, who has direct access to it and how is that secured?	

4. Input Validation & API Security

How does the app handle untrusted input and protect its endpoints?

#	Question	Response
1	How is user input validated (e.g., form fields, search bars, file uploads)?	
2	Are API endpoints protected against unauthorized access?	
3	Is there rate limiting on login attempts or API calls?	
4	If users can upload files or images, are file types and sizes restricted?	

MOBILE APP SECURITY QUESTIONNAIRE

5 Are error messages generic (not leaking stack traces or database info to the user)?

5. Privacy & Permissions

What data is collected, what device access is requested, and is the user informed?

#	Question	Response
1	What device permissions does the app request (camera, location, contacts, storage)?	
2	Is each permission necessary for core functionality? Justify any that aren't obvious.	
3	Is there a privacy policy or data usage notice presented to the user?	
4	Is any data shared with third-party services (analytics, ads, crash reporting)?	
5	Can users delete their account and associated data?	

6. Development Practices

How does the team manage code, dependencies, and security during development?

#	Question	Response
1	Is source code stored in a private repository?	
2	Are there any secrets, API keys, or credentials committed to the repo?	
3	Are dependencies kept up to date? Is there a process to check for known vulnerabilities?	
4	Does the team conduct code reviews before merging?	
5	Is there a plan for what to do if a security bug is discovered after deployment?	

MOBILE APP SECURITY QUESTIONNAIRE

Sign-Off

By signing below, the respondent confirms the information provided is accurate to the best of their knowledge.

Completed By

Role on Team

Date